RIESGO-GESTITEL

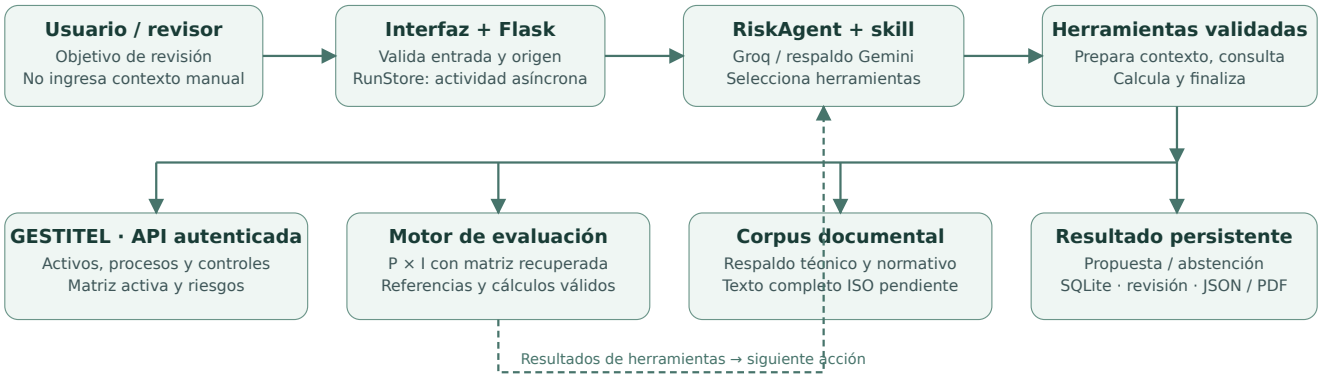
Ficha de entrega · Segunda entrega TIF / EC2 · Grupo 1

Integrantes: Barrios Medina Matias Alonso; Carbajal Gonzales Diego Alejandro; Cari Lipe Paul Andree; Mamani Huarsaya Jorge Luis.

Objetivo, datos y alcance

Apoyar la identificación, evaluación y tratamiento propuesto de riesgos de seguridad de la información. El contexto operativo proviene exclusivamente de GESTITEL: activos, procesos, matriz activa, evaluaciones y controles. El usuario indica el objetivo; el agente selecciona herramientas y devuelve escenarios, justificaciones, acciones y evidencia a solicitar. Un único agente; las dependencias de otros módulos son fuentes de datos, no agentes adicionales.

Arquitectura y orquestación



Un único agente · contexto exclusivo de GESTITEL · conexión de solo lectura · revisión humana

Flujo: cargar skill → recuperar contexto → seleccionar herramientas → calcular y verificar → entregar propuesta o evidencia insuficiente → revisión local. Groq es principal y Gemini respaldo ante ciertos fallos. Python valida argumentos, escala, referencias y correspondencia del activo. Hay traza, presupuesto de ejecución e historial persistente.

Cláusulas y controles de referencia

Referencia ISO/IEC 27001:2022	Función y alcance del agente
6.1.2	Apoya identificación, análisis y evaluación mediante matriz recuperada y estimaciones justificadas. No determina aceptación corporativa.
6.1.3	Propone opciones, controles y acciones de tratamiento; no aprueba la SoA ni acepta riesgo residual.
8.2 / 8.3	Apoya reevaluación bajo solicitud y documentación del tratamiento propuesto; no acredita implementación de medidas.
A.5.9 / A.5.15	Inventario de activos y control de acceso: referencias candidatas según el escenario y catálogo recuperado.
A.8.13 / A.5.30	Copias de seguridad y preparación TIC para continuidad: referencias candidatas para el caso académico.

Correspondencias de diseño basadas en el catálogo de GESTITEL. Pendiente incorporar los textos ISO autorizados y contrastar su redacción. ISO/IEC 27005 orienta la metodología; no se afirma certificación ni cobertura completa de las cláusulas.

Demostración y acceso

Modalidad PC: ejecutar `./iniciar.sh` y abrir `http://127.0.0.1:5000` (o el puerto configurado). No requiere cuenta web local; las credenciales de GESTITEL y proveedor se guardan en `.env` y no se incluyen en esta hoja. Caso EC2-DEMO: proceso y servidor ficticios registrados en GESTITEL, sin datos personales. Mostrar recuperación, evaluación, control citado, tratamiento, revisión e informe. Tiempo previsto: 12 minutos + 3 de preguntas.

Límites: conexión operativa de solo lectura; las propuestas y revisiones se guardan localmente. La integración está realizada contra la API; no se modifica el frontend externo. Un campo sin evidencia no demuestra ausencia del control. La fórmula P×I está documentada en el Anexo 04 de GESTITEL, páginas PDF 6 y 10; la matriz se consulta en vivo.